PatchProof | Executive Security Summary

Evidence-based vulnerability management MVP • Assessment snapshot: 26 October 2026

Executive conclusion

A controlled-lab assessment and reporting pipeline is operational. Two WEB01 security-header findings were remediated and recorded as verified, reducing the imported operational review queue from 10 to 8. These figures represent partial scan coverage; notably, authenticated Nessus patch findings are not yet included.

BASELINE RECORDS	CVEs ENRICHED	VERIFIED FIXES	OUTSTANDING OPERATIONAL
80 (76 Greenbone + 4 ZAP)	93 distinct (125 associations)	2 WEB01 header fixes	8 findings require review

What was demonstrated

Scanner results were normalized and correlated with FIRST EPSS and CISA KEV. A deterministic risk heuristic produced a review backlog, while local Ollama Qwen3:4b generated ten draft analyses for human review. PostgreSQL powers a live-query Grafana executive dashboard and stores verification records.

Verified improvement

The WEB01 Flask application now returns X-Frame-Options: DENY and X-Content-Type-Options: nosniff on tested routes. Dated before/after HTTP-header captures and a fresh OWASP ZAP report support verification. ZAP continues to report other issues, including missing CSP and server-version disclosure; the application is not claimed secure.

Where leadership should focus

Complete Windows assessment coverage: Import authenticated DC01 Nessus patch results; resolve WIN-CL authenticated scanning; validate WSUS client registration separately. Contain deliberately vulnerable MS2: Confirm network isolation before further lab use. Govern AI output: Require human validation of generated remediation narratives.

Important qualifications

The 80 records are scanner observations, not 80 independent confirmed CVEs. The two KEV matches occur in the intentionally vulnerable MS2 training environment, not the currently imported operational findings. Grafana reflects database updates; recurring scanner ingestion is not automated. Coverage labels are categorical, not measured percentages.

Decision recommended: Accept this as a demonstrated portfolio MVP and prioritize completing credentialed coverage and lab isolation before making any production-like risk claims.